

PCI SAQ Readiness Kit for Small Merchants

Build an organized, reviewable readiness file: a documented candidate SAQ path, a scope inventory with reduction actions, a tracked readiness log, a posted incident plan, and a renewal calendar you can maintain year after year.

Galaxy Forge Implementation Kit | Version 1.0 | September 2026

Companion files: Excel workbook, editable Word templates, README.

PCI SAQ Readiness Kit for Small Merchants - Guide

1. Who this kit is for and how to use it

This kit serves owners and office managers of small businesses in the United States that accept card payments at the counter, online, by phone, or by mail. It fits retail shops, food outlets such as cafes and takeout counters, and services firms such as repair shops, salons, and small offices. It assumes no background in security or compliance work. Every step uses plain language, and every workbook sheet includes notes that explain what to enter.

The problem this kit addresses is practical. Each year, small merchants must complete a self-attestation questionnaire about how they handle card payments. Many owners do not know which questionnaire path applies to their setup. Small details widen the scope of what must be covered: an old computer in the back room, emailed reports that include card numbers, a website that passes card data through its own server, or remote access left open for a vendor. When scope grows, the paperwork grows with it, and merchants can drift toward the heavy SAQ D path, which is the longest and most demanding option. Failed attestations create rework, strained conversations with the bank, and continued exposure to breach liability.

This kit contains five linked tools. The SAQ selector worksheet walks you through a decision tree and produces a candidate path to discuss with your acquirer. The scope inventory lists every place card data could appear so you can shrink that list on purpose. The readiness log tracks each requirement from not started to confirmed with a place for evidence. The incident-response plan template gives staff a one-page routine for the first hour of a suspected incident. The renewal calendar keeps attestation,

provider reviews, and plan tests on schedule. No single tool works alone. Used in order, they build one organized file you can review with your acquirer or bank.

Work through the guide chapters in order the first time. Chapter 2 gives background on the questionnaire system. Chapters 3 and 4 explain the two costliest mistakes: picking the wrong path and letting scope grow. Chapters 5 through 8 teach each tool. Chapters 9 and 10 cover incident planning and the calendar. Chapter 11 gives three worked illustrative examples. Chapter 12 answers common questions. Chapter 13 states limitations and disclosures. Plan on several short sessions rather than one long sitting. A realistic pace is one chapter and its matching workbook sheet per sitting, with time between sessions to gather papers and ask staff how things actually work.

Throughout this guide, the word illustrative marks simplified teaching cases with invented numbers. They show how to use the tools. They are not assessments of any real business, and they do not predict any outcome for your business. Where the guide states a fact about the questionnaire system, it stays at the level of general background that any merchant can verify with their acquirer. Specific requirement text changes over time, so this guide describes requirement areas in plain language and tells you where to file the current official text when you receive it from your acquirer or processor.

A final note before you begin: no compliance guarantees; your acquirer/bank decides what is required. Nothing in this kit promises a specific SAQ outcome. The kit helps you prepare an organized file and ask sharper questions. The decision on which questionnaire path applies, and whether an attestation is accepted, rests with your acquirer or bank.

2. Background on card compliance for small merchants

When a customer pays by card, several parties touch the transaction. Your business takes the payment. A processor moves the transaction details. An acquirer, usually connected to your bank, settles the funds. Card brands set the rules that flow down through contracts. As a merchant, you agree to handle card data with care, and each year you attest that your handling meets the applicable standard.

For small merchants, attestation usually means a self-assessment questionnaire, often shortened to SAQ. Multiple SAQ types exist for different environments. A shop that uses only a standalone countertop terminal supplied by its processor faces a different set of questions than a shop whose website collects card numbers on its own server. A merchant that stores card numbers faces different questions than one that never stores them. The questionnaire path follows the facts of your environment, not the size of your revenue or the number of employees.

Self-attestation means you answer the questions yourself, gather evidence, and sign. It does not mean the answers go unchecked. Your acquirer can ask for clarification, request evidence, or direct you to a different questionnaire path. Processors also impose their own checks, such as terminal inspections or website scans, depending on how you accept payments. Treat self-attestation as organized self-reporting with outside review, not as a private exercise.

Outsourcing card handling to compliant providers shrinks scope dramatically. When a validated terminal, a hosted payment page, or a compliant gateway handles card numbers so that they never touch your computers, network, or paper files, the systems you must cover become fewer. This is the single most powerful idea in this kit. Every card number that never reaches your environment is a card number you do not have to track, log, or defend in the questionnaire. Chapters 5 and 6 turn this idea

into a repeatable routine: first map where card data could appear, then remove or reroute as many of those points as practical, then document what remains.

Two gaps appear again and again in small businesses. The first is access control around payment equipment and records, including multi-factor authentication where remote access exists. Shared logins, default passwords left unchanged, and former employees whose access was never removed are typical findings. The second is the absence of an incident plan. Many owners have never written down who to call, what to preserve, and what to record if card data is suspected to be exposed. Both gaps are fixable without special expertise, and both are covered in this kit with dedicated tools.

Terminology in this area can feel dense, so this guide uses a small set of plain terms consistently. Scope means every system, device, paper file, and person that touches card data or could affect its safety. Evidence means a named file, photo, log, or record that shows a step was actually done. Attestation means the signed questionnaire and any attachments you submit. Renewal means the yearly cycle of reviewing, updating, and resubmitting. Keep these four meanings in mind and the rest of the guide will read clearly.

3. Why SAQ selection confuses owners

Confusion over which questionnaire applies has several roots. First, business setups change gradually while memory of the original setup fades. A terminal installed years ago may have been joined by online ordering, emailed receipts, a new back-office computer, or a vendor who connects remotely to fix the register. Each addition can change which questionnaire path fits, but nobody records the change as a compliance event. By attestation time, the owner describes the shop as it was three years ago, not as it is today.

Second, advice comes from too many directions. The terminal salesperson says one thing, the website developer says another, a fellow owner says a third, and the bank letter says something terse that is hard to parse. Each source speaks from its own slice of the picture. The salesperson knows the terminal but not the email habit in the back office. The developer knows the website but not the paper receipts in a drawer. Only the owner can assemble the full picture, which is exactly what the scope inventory in Chapter 6 is for.

Third, questionnaire names and letters look similar and invite guessing. Owners sometimes pick the path a friend uses, or the path used last year, or the shortest-looking one. Any of these guesses can be wrong after even a modest change in setup. A wrong pick costs time at minimum: the acquirer returns the paperwork and asks for the correct path. At worst, a business operates for months believing it attested correctly while the real gaps sit uncovered.

Fourth, fear plays a role. Owners worry that asking the acquirer which path applies will invite scrutiny. In practice, the opposite is true. Acquirers prefer a merchant who asks early and files correctly over one who files the wrong path and needs rework. The confirmation letter draft in this kit exists for exactly this conversation. It asks for written confirmation of the path and the due date, in polite business language, with a clear description of the current setup attached. Filing the reply with the attestation papers closes the loop.

The remedy this kit offers is a documented candidate path. You answer the decision-tree questions in the SAQ selector worksheet, record who answered and when, attach the scope inventory as supporting detail, and send the confirmation letter. The result is not a self-declared verdict. It is a tidy package that

lets your acquirer confirm or correct the path quickly. Even when the acquirer corrects the path, the package was not wasted: the inventory and evidence you gathered carry over to the correct questionnaire with little rework.

4. Scope creep and the drift toward the heavy path

Scope creep is the quiet growth of systems and habits that touch card data. It rarely announces itself. A staff member forwards a transaction report to a personal email to work from home. A manager photographs a receipt to send to the bookkeeper. An old laptop stays in storage with its drive intact. A website plugin update reroutes the checkout page through the shop server for a week. Each event seems small. Together they widen the set of systems the questionnaire must cover, and the business drifts toward the heavy SAQ D path, which covers the broadest set of requirements and demands the most evidence.

The heavy path is not a punishment. It is the questionnaire designed for environments where card data flows through many systems. Its length reflects that breadth. For a small shop, landing there usually signals that scope grew beyond what the business actually needs, not that the business is large or complex. That is why scope reduction is the highest-return activity in this kit. Removing one unnecessary card-data touchpoint can remove a whole family of follow-up questions and evidence chores.

Common creep points deserve a deliberate walkthrough at least once per year. Start with email. Search inboxes for messages containing card numbers or full transaction reports, and change the routine so reports stay inside the processor portal instead of traveling by email. Continue with paper. Look in drawers, receipt spikes, notebooks, and sticky notes near the register for written card numbers, and replace any such habit with processor-provided reprint or lookup functions. Check old devices. List every retired terminal, computer, tablet, and phone, and confirm drives were wiped or devices destroyed with a dated note. Check remote access. List every vendor or staff member who can connect from outside, confirm each account is still needed, and confirm that shared passwords are gone. Check the website. Confirm with the developer or host, in writing, whether card numbers pass through or are stored on the shop server, and keep that statement in the file.

Each check ends in one of three dispositions: keep, change, or remove. Keep means the touchpoint is needed and will be covered by the questionnaire with evidence. Change means rerouting card handling to a compliant provider or tightening access, with a target date and an owner. Remove means eliminating the touchpoint, such as wiping an old drive or ending an emailed-report habit, with a dated completion note. The scope inventory sheet has columns for exactly these dispositions. Review the sheet quarterly so new creep is caught while it is still small.

A note on limits: this guide cannot see your shop, so it cannot tell you which touchpoints are safe to remove. It gives you the routine for finding and deciding. When a removal touches how customers pay, test the new flow during a quiet hour with staff present before making it permanent. Keep the test note in the file alongside the change record.

5. The SAQ selector decision tree step by step

The SAQ selector worksheet turns a confusing choice into a sequence of small factual questions. Answer them in order, one row at a time, and do not skip ahead. Each question asks about a fact you can verify by looking at equipment, asking staff, or reading a provider statement. The columns guide you: the question, your yes or no answer, where to go next for each answer, and a notes field for the detail that supports the answer.

Begin with how payments are accepted today. List every channel: counter terminal, online checkout, phone orders, mail orders. For each channel, write down the equipment or service involved and the supplier. This list becomes the backbone of the whole file. If a channel is missing here, every later step inherits the gap, so take time to get it right. Ask every person who takes payments, not just the manager, because side habits such as phone orders taken at the back desk often surface only when you ask directly.

Next, establish whether card numbers touch your own systems. This is the pivot of the entire tree. Card numbers that stay inside a validated terminal or a hosted payment page are in a different situation than card numbers typed into your computer, stored in your email, written on paper, or passing through your website server. Answer from evidence, not memory. Look at the terminal model and its documentation. Ask the website host for a written statement. Check the email and paper habits found during the scope walkthrough. Where the answer is unknown, write unknown and treat it as a task to resolve, not as a no.

Continue through the remaining steps, which narrow the candidate path based on which channels exist and how each one handles card data. Record the date and the role of the person answering each row. When two staff members disagree about a fact, note the disagreement and verify by observation: watch the next three transactions on that channel and record what actually happens. Observation beats recollection in this exercise.

The worksheet ends with a candidate path, not a verdict. Copy that candidate path onto the confirmation letter draft, attach the scope inventory, and ask the acquirer for written confirmation. The two count formulas at the top of the sheet help you check completeness: the answered count should equal the number of steps, and any unanswered step should be resolved before sending the letter. File the acquirer reply with the worksheet. If the reply corrects the path, update the worksheet notes with the correction date rather than rewriting history. A visible correction trail shows diligence, which is exactly what reviewers want to see.

Revisit the selector whenever the setup changes: a new terminal, a new website, a new phone-order routine, a new vendor with remote access, or a move to a new address. A five-minute rerun after each change prevents the slow drift that otherwise surfaces as a surprise at attestation time.

6. Scope inventory and the scope-reduction planner

The scope inventory is a complete list of every location, device, account, and habit where card data could appear. Completeness matters more than polish. A messy but complete list protects you. A tidy but partial list does not. Walk the premises with the sheet on a clipboard or tablet. Open drawers. Look behind the counter. Ask about home computers used for shop work. Ask about personal phones that photograph receipts. List retired equipment in storage. Include the website, the email accounts, and every vendor connection.

For each row, record how cards are handled there, who owns the area, and the disposition: keep, change, or remove. Assign a target date and track completion. The unknown count formula at the top of the sheet is your early warning signal. Every unknown is an investigation task. Drive that count down by asking, observing, and requesting written statements from providers. A scope inventory with zero unknowns and dated dispositions is a strong artifact to show any reviewer.

The scope-reduction planner is the decision routine you run against the inventory. For each row marked change or remove, write the replacement flow in one sentence. Examples of replacement sentences, all illustrative, include routing emailed reports back inside the processor portal, replacing written card numbers with processor reprint functions, replacing shop-server checkout handling with a hosted payment page, and removing remote access accounts that no one uses. Each replacement needs an owner, a target date, and a test note. Test during quiet hours, confirm customers can still pay smoothly, and then record completion with a date.

Prioritize reductions by breadth of effect. Removing card numbers from email habits often collapses several rows at once, because every inbox that held card data was separately in scope. Retiring old devices with a dated wipe note removes an entire category of questions about media handling. Rerouting website handling to a hosted page can be the largest single reduction for shops that sell online. Sequence the work so the broadest reductions come first; the readiness log becomes shorter for everything that follows.

Outsourcing deserves emphasis because it is the most reliable reduction lever. When a compliant provider handles card numbers end to end for a channel, your remaining duties for that channel center on oversight: keeping the provider list current, filing their responsibility statements, controlling physical access to terminals, and following the incident plan. Outsourcing does not outsource responsibility. It narrows the systems you must defend, which is precisely what makes the rest of the questionnaire manageable for a small team.

Document every reduction as you go. Keep provider statements, wipe notes, configuration printouts, and test notes in one folder, named to match the inventory rows. The readiness log in the next chapter points to these files as evidence. A reviewer who can walk from an inventory row to a dated evidence file sees a business that runs this process rather than one that filled out forms the night before the deadline.

7. Readiness log requirement by requirement

The readiness log turns each requirement area into a tracked row with a status, an owner, evidence, and dates. The four statuses are defined narrowly. Not started means no work has begun. In progress means work is under way but evidence is not yet filed. Ready for review means the owner believes the work is done and the evidence is filed, awaiting a second look. Confirmed means a second person checked the evidence and agreed. Only confirmed rows count in the completion formula. This discipline prevents the common failure where everything is marked done but half the evidence is missing.

Work the log in small batches. A practical rhythm is three rows per week, starting with access control and provider oversight, which are the most common gaps. For each row, write the evidence location as a specific file or place, not a vague note. Good evidence entries name the drawer, folder, or file: terminal setup printout in folder 2, door code list dated this month, provider responsibility letter from the

processor. Vague entries such as handled or ok signal unfinished work and should stay at in progress.

Access control rows deserve care. Confirm that default passwords on payment equipment were changed, that each user has a separate login where the equipment supports it, that former staff access was removed, and that remote access uses additional verification where available. Multi-factor authentication is a common gap because small shops often do not realize remote access is even enabled. Ask the terminal supplier and any IT support firm, in writing, whether remote access exists and how it is protected. File their replies. Where the equipment is too simple for separate logins, record that fact with the model number and focus protection on physical access: who holds keys, who knows codes, and how often codes change.

Provider rows track the outside companies that touch payments. For each provider, the log should point to a current responsibility statement or compliance document, a contact, and a review date. Provider documents expire or go stale as services change, so the renewal calendar schedules these reviews quarterly. When a document is missing, the log row stays at in progress or not started, and the gap is visible in the summary formulas rather than hidden.

Date hygiene keeps the log honest. Every row carries a last-checked date and a next-check date. When you verify a row, update both. Stale dates are information: a row confirmed eleven months ago with no intervening check is a candidate for re-verification, not a permanent pass. The summary formulas count confirmed rows and not-started rows so the owner sees the real shape of the work at a glance. Review these counts at the start of each month and assign owners to the next batch.

8. Service providers and access control gaps

Small merchants rely on providers for nearly everything about payments: the terminal on the counter, the gateway behind the website, the processor that moves money, the host that runs the site, and sometimes an IT firm that fixes things remotely. This reliance is healthy when it is managed. It becomes a gap when the merchant cannot name the providers, cannot produce their current documents, or cannot say who at the shop oversees each relationship.

Build the provider list once, then maintain it quarterly. For each provider, record the service, a contact, the document received with its date, and the next review date. Request responsibility statements in plain terms: ask what the provider handles, what remains your duty, and where that division is written down. File replies by provider name. When a provider changes, or when you add online ordering or switch terminal suppliers, update the list within the same week. The provider list template in this kit gives you the exact block to copy per provider so the format stays consistent year after year.

Access control around payment handling needs the same steady attention. List every person who can touch terminals, open transaction reports, enter the area where equipment sits, or connect remotely. Remove access promptly when staff leave or vendors change. Change shared codes whenever the circle of people changes. Where equipment allows, give each user a separate login and review the user list at least twice per year. Where remote access exists, confirm with the supplier how it is protected and whether additional verification is active. File the supplier reply with the access rows of the readiness log.

Physical habits matter as much as digital ones. Terminals should sit where staff can watch them, with cables and seals checked on a simple routine. Paper with card numbers should not exist, and where a legacy habit produces it, the habit should be redesigned rather than tolerated. Screens showing

transaction details should face away from customer lines. These sound like small points, and each one is small, but together they form the visible layer of care that reviewers, and more importantly criminals, notice first.

Two mistakes recur in this area. The first is filing provider marketing material as if it were a responsibility statement. A brochure that says the provider is secure does not say what you must still do. Ask for the document that divides duties, and keep asking until you receive it. The second is treating access review as a one-time cleanup. Staff turn over, vendors change, codes leak through ordinary conversation. The renewal calendar therefore schedules access and provider reviews as repeating tasks, not as single events.

9. Incident-response plan

An incident plan answers three questions before anything goes wrong: who do we call, what do we preserve, and what do we write down. In the stress of a suspected card-data exposure, nobody should be improvising these answers. The one-page template in this kit fits on a single posted sheet so the shift lead can act within minutes.

The call list comes first. It names the processor incident line, the acquirer contact, and the internal owner, with an alternate for each. Verify every number at least twice per year by placing a short verification call or confirming the numbers against current provider letters. Log the verification date on the calendar. An untested call list is barely better than none, because numbers change and staff forget which line is which.

Preservation comes second. The plan instructs staff not to switch off, wipe, or reconfigure affected equipment until the processor or investigator advises. This instruction feels counterintuitive, and that is why it must be written down in advance. Well-meaning cleanup can destroy the evidence investigators need to determine what happened. Limit access to the affected area to the owner and one named staff member, and record who entered and when.

Recording comes third. The plan provides fields for the time the issue was noticed, who noticed it, which device or area is affected, and what was observed. Start this note within the hour and keep adding dated entries as events unfold. Keep the note with the incident file. Accurate early notes consistently shorten and cheapen investigations, while reconstructed memories written days later invite doubt.

Rehearsal turns the page into a capability. Once per year, walk through a hypothetical case with the people named in the plan: a terminal that behaves oddly, a report found in an unexpected inbox, a vendor call about suspicious transactions. The walkthrough takes under an hour. Record the date, the attendees by role, and the gaps found. Common gaps include a missing alternate contact, an unposted sheet after a remodel, and new staff who never saw the plan. Close each gap with an owner and a date, and file the walkthrough note with the plan.

This chapter cannot cover forensic investigation, legal notification duties, or breach reporting rules, which vary and require professional advice. The template states its boundary plainly and carries the disclosure that no compliance guarantees apply and that your acquirer and bank decide what is required. Treat the plan as the first hour done right, followed by professional guidance, not as a complete legal response.

10. Attestation and renewal calendar

The renewal calendar converts a yearly scramble into a steady routine. It lists each recurring task, its frequency, the last done date, the next due date, the owner, and a status. Review it at the start of each month. Update last done dates the same day work completes so next due dates stay truthful. The overdue and not-scheduled counts at the top of the sheet tell you whether the system is healthy or slipping.

Annual tasks anchor the cycle. Confirm the questionnaire path with the acquirer in writing each year, even if nothing seems to have changed, because provider services and requirement text change without notice. Complete the questionnaire with current evidence, sign, and file the signed copy with the acquirer reply and all evidence references. Review the incident plan with named staff and record the walkthrough. Confirm the provider list is current and every document is fresh.

Quarterly tasks keep scope and providers under control. Re-scan the scope inventory for new touchpoints: new devices, new email habits, new vendors, website changes. Review the provider list and chase missing documents. Check the readiness log summary counts and assign the next batch of rows. These short sessions prevent the year-end discovery that the setup changed in spring and nobody recorded it.

Semiannual tasks cover the items that decay quietly. Test the incident call list. Review who holds keys, codes, and remote access, and remove what is no longer needed. Confirm retired equipment handling is documented. These checks take little time when done twice per year and become painful when deferred for years.

Schedule discipline matters more than scheduling cleverness. Put the monthly calendar review on a fixed day, such as the first Monday, with a named owner. If the owner is unavailable, a named alternate runs the review rather than skipping it. Keep one folder per year with the signed questionnaire, the acquirer correspondence, the provider documents, the walkthrough notes, and the workbook printouts or files. When the next cycle starts, copy the calendar forward and keep the evidence folder as history. Year-over-year folders show a pattern of care that any reviewer reads favorably.

11. Worked illustrative examples

The three cases below are illustrative teaching cases with invented details. They show how different shops would use the kit. They are not assessments of any real business.

Illustrative case one: a corner retail shop with a countertop terminal. The owner believes only the terminal touches card data. Walking the scope inventory with the office manager surfaces two extras: emailed transaction summaries that arrive each morning and a retired terminal in the storage room. The selector worksheet records a candidate path based on terminal-only handling plus the email habit flagged for removal. The reduction plan reroutes morning reconciliation inside the processor portal and records a dated wipe note for the retired device. The readiness log tracks access rows for the terminal area and provider rows for the processor and terminal supplier. The incident one-pager is posted by the register with verified call numbers. The calendar schedules annual path confirmation and quarterly provider reviews. The file that results is small but complete, and the acquirer reply confirming the path is filed on top.

Illustrative case two: a food outlet with counter sales and new online ordering. The owner added online ordering through a website developer six months ago and is unsure whether card numbers pass through the shop server. The selector worksheet marks that question unknown rather than guessing. The owner requests a written statement from the developer and host, which states that checkout was rerouted through a hosted payment page after an update, with dates. The scope inventory lists the counter terminal, the website, and the email account that receives order notifications, and the reduction plan confirms notifications carry no card numbers before marking those rows as keep with evidence. The provider list gains the host and gateway alongside the processor. The readiness log tracks the new provider documents to confirmed. The incident plan adds the website contact to the call list. The lesson of the case is the value of writing unknown instead of guessing: one written statement resolved the central question for the whole file.

Illustrative case three: a services firm that takes phone orders and sends emailed receipts. The scope walk finds the widest starting footprint: card numbers dictated by phone, typed into a back-office computer, and echoed in emailed receipts. The selector candidate path reflects this broader handling. The reduction plan is phased: first stop echoing card numbers in receipts and use processor reprint functions instead, then move phone payments to a compliant entry method supplied by the processor, then confirm the back-office computer no longer holds card data with a dated check note. Each phase has an owner, a target date, and a test note from a quiet-hour trial. The readiness log moves rows to confirmed only as each phase completes with evidence. The calendar carries the phase dates alongside the annual attestation. The case shows the kit handling a harder starting point without drama: the same sheets, the same dispositions, the same evidence discipline, applied in phases.

12. Frequently asked questions

Which questionnaire path applies to my business. Build a candidate path with the selector worksheet and ask your acquirer in writing with the confirmation letter draft. The acquirer reply controls. Do not adopt a path because a friend uses it or because it looks shorter.

Why do small merchants drift toward the heavy path. Because card handling touches more systems than the owner realizes: old devices, email, website servers, remote access. The scope inventory exists to surface these before they dictate the path.

Do I need technical background. No. The kit is written for owners and office managers. Where a technical fact is needed, such as website handling or remote access protection, the kit tells you exactly what to ask the supplier and how to file the reply.

If my processor handles cards, is there nothing left for me. There is. Outsourcing narrows scope but leaves duties such as provider oversight, physical access control, incident planning, and accurate attestation with you. The readiness log tracks these remaining duties.

How long does the first pass take. Illustrative planning figures only: many shops complete the selector and inventory in two or three short sessions, then work the readiness log a few rows per week. Dated illustrative schedules in this guide are teaching aids, not promises about your timeline.

What if the acquirer corrects my candidate path. Update the worksheet notes with the correction date, carry the inventory and evidence forward, and complete the indicated path. The work is preserved.

How do I handle a setup change mid-year. Rerun the selector, update the inventory, adjust the calendar, and notify the acquirer if the change affects the path. Small reruns prevent large surprises.

What belongs in the evidence folder. The signed questionnaire, the acquirer correspondence, provider documents, wipe and configuration notes, walkthrough records, and the workbook files. Name files to match inventory and log rows so a reviewer can trace each claim to its proof.

Who should own this process. The owner holds accountability. The office manager often runs the weekly rhythm. Name both, plus an alternate, in the calendar so absences do not stall the cycle.

Does this kit replace professional advice. No. It organizes your file and sharpens your questions. Your acquirer, and where needed a qualified assessor or legal counsel, supply the authoritative answers.

13. Limitations and disclosure

This kit is general operational guidance for organizing a small merchant attestation file. It is not legal advice, not security advice, and not an audit service. It does not determine which questionnaire path applies to any business, does not validate any control, and does not attest on anyone behalf.

Requirement text and acquirer expectations change over time. Verify current expectations with your acquirer or bank before filing.

No outcome is promised. Completing the worksheets does not promise acceptance of any attestation, does not promise any particular questionnaire path, and does not promise protection against breach or liability. Illustrative examples and any illustrative numbers in this guide are simplified teaching cases, not measurements from any real business and not predictions for yours.

The standing disclosure for this kit is: no compliance guarantees; your acquirer/bank decides what is required. This sentence also appears in the incident-response template and the confirmation letter draft so that anyone who sees only one file still sees the boundary. Keep the acquirer written reply as the controlling document in your file. If any part of this guide ever seems to conflict with written acquirer instructions, follow the acquirer instructions and note the difference in your file.

Support for this kit covers file access and how-to-use questions. Questions about which path applies, what evidence suffices, or how to respond to an incident should go to your acquirer, processor, or qualified professional. That routing is deliberate: the parties who decide what is required are the parties who should answer those questions.